الثالوث والطبقات في حماية الشبكات

Lecture 1 — Principles and Core Concepts

> **Computer network** : a group of connected devices that communicate and exchange information (computers, phones, servers, switches, routers, access points, cameras, printers, IoT).

Device	Main role
Switch	Connects devices **inside** a local network
Router	Connects one network to **another** / the Internet
Server	Provides data or services
Wireless AP	Connects wireless devices (provides Wi-Fi)

> **Network security** : protecting network devices, services, users and information against **unauthorized access, misuse, modification, damage, or interruption**.

Q/ What does network security protect ?

1. Stored and transmitted data.
2. User accounts and passwords.
3. Servers, applications, devices and communication channels.

Key idea: connecting devices improves communication, but **every connection can also create a security risk**.

Q/ What are the common consequences of a security incident ?

1. Loss of confidential information.
2. Financial loss.
3. Service interruption.
4. Loss of important files.
5. Legal or reputation problems.
6. Loss of user trust.

The CIA Triad

> **Confidentiality** : only authorized users can **read** information.

> **Integrity** : information stays **correct** and is changed only by authorized users.

> **Availability** : authorized users can access systems and data **when needed**.

Objective	Typical protections	Violation example
Confidentiality	Encryption, passwords, access control, VPN	Attacker captures an unencrypted username and password
Integrity	Hashes, digital signatures, permissions, logging	"Transfer $100" changed to "Transfer $1,000"
Availability	Backups, redundancy, UPS, updates, DoS protection	Server flooded with traffic, can't serve users

Q/ Apply CIA to a university examination system.

1. Confidentiality → students can't view exam questions before the exam.
2. Integrity → students can't change grades.
3. Availability → the system is accessible during the exam.

A secure system needs **all three**. Protecting only one is not enough.

Authentication, Authorization, Accountability

Concept	Question	Example
Authentication	Who are you?	Password, fingerprint, smart card, OTP
Authorization	What are you allowed to do?	Student views grades; teacher modifies grades
Accountability	What did you do?	Logs record who changed data, when, from which device

Order: authenticate → authorize → record. **Authentication comes first.**

Terminology

Asset : anything valuable that must be protected.

Threat : something that can **potentially** cause harm.

Vulnerability : a **weakness** in a system, device, configuration, policy or procedure.

Attack : an **intentional action** that tries to exploit a vulnerability.

Risk : the possibility that a threat exploits a vulnerability and causes harm. **Risk ≈ Likelihood × Impact**.

Security control : a protection used to **reduce risk**.

Example: weak admin password (**vulnerability**) + attacker (**threat**) → password guessing (**attack**) → unauthorized grade changes (**risk**).

Passive vs active attacks

Passive attack	**Active attack**
Observes or collects information	**Changes** information or system operation
Normally doesn't modify data	May modify, delete, inject or disrupt
Often difficult to detect	Often produces visible effects
Mainly affects confidentiality	Mainly affects **integrity and availability**
Sniffing, traffic analysis	DoS, malware, spoofing, unauthorized access

Encryption works well against passive eavesdropping; active attacks also need detection, access control, filtering and recovery.

Security controls

Category	Purpose	Examples
Administrative	Rules and human processes	Security policy, password policy, training, incident procedures
Technical	Hardware or software protection	Firewall, encryption, antivirus, IDS, authentication, ACLs
Physical	Protect facilities and equipment	Locks, guards, cameras, access cards, fire alarms, backup power

Q/ How should controls be chosen ?

- According to the **assets** protected, likely **threats**, known **vulnerabilities**, and the **impact** of an incident. Strong security combines all three categories.

A firewall can't replace user training; a strong password can't replace physical protection of the server room.

> **Defense in depth** : using **several layers** of security so that if one layer fails, another still reduces the damage.

Q/ List the layers of defense in depth from the lecture.

1. Locked server room — physical protection.
2. Authentication & strong passwords — control user access.
3. Firewall & antivirus — block threats and malware.
4. Encryption — protect sensitive data.
5. Network monitoring — detect suspicious activity.
6. Regular backups — recover lost data.
7. Security awareness training — reduce human errors.

Q/ University case study — assets, threats, controls ?

- **Assets**: student records, exam questions, passwords, research files.
- **Threats / vulnerabilities**: attackers, malware, weak passwords, old software, open Wi-Fi, no backups.
- **Controls**: MFA, firewall, encryption, updates, antivirus, monitoring, backups, training.

Q/ What are the rules for ethical use of security tools ?

1. Work only on systems you have **permission** for.
2. Follow laboratory and university rules.
3. Don't access other users' files or capture private information.
4. Don't scan external systems without authorization.
5. Protect passwords and report security problems to the instructor.

> Technical ability does **not** provide legal permission.

Summary of Network Security L1: Principles & Core Concepts. Built only from the lecture file; check the original slides for anything you're unsure about.